

Gluwa Soulbound Contract Security Audit

: Soulbound Contract Security Audit

March 10, 2026

Revision 1.0

ChainLight@Theori

Theori, Inc. ("We") is acting solely for the client and is not responsible to any other party. Deliverables are valid for and should be used solely in connection with the purpose for which they were prepared as set out in our engagement agreement. You should not refer to or use our name or advice for any other purpose. The information (where appropriate) has not been verified. No representation or warranty is given as to accuracy, completeness or correctness of information in the Deliverables, any document, or any other information made available. Deliverables are for the internal use of the client and may not be used or relied upon by any person or entity other than the client. Deliverables are confidential and are not to be provided, without our authorization (preferably written), to entities or representatives of entities (including employees) that are not the client, including affiliates or representatives of affiliates of the client.

Table of Contents

Gluwa Soulbound Contract Security Audit	1
Table of Contents	2
Executive Summary	4
Audit Overview	5
Scope	5
Code Revision	5
Severity Categories	6
Status Categories	8
Finding Breakdown by Severity	9
Findings	10
Summary	10
#1 GLUWASOULBOUND-001 Minor Suggestions	11
Revision History	13

Executive Summary

From December 9 to December 10, 2025, Theori's ChainLight team conducted a 2-day security audit of Gluwa's SoulboundNFT contract. The assessment focused on a non-transferable ERC-721 implementation in which the contract owner can register and manage artifact types, mint soulbound NFTs tied to artifact metadata, and control upgrade authorization. The review covered initialization, artifact management, owner-only minting flows, artifact-to-token association, and enforcement of non-transferability through disabled approval and transfer functions. No major issues were identified during the audit. Four minor issues were noted, including an inefficient return pattern in `getActiveArtifacts`, variable shadowing in `SoulboundNFT_init`, redundant artifact activity checks in public minting functions, and an unnecessary `fallback()` function.

Audit Overview

Scope

Name	Gluwa Soulbound Contract Security Audit
Target / Version	Git Repository (<code>gluwa/StandardSoulbound</code>): commit <code>00149d3b785de1fbec295a323a19bae860e1eae8</code>
Application Type	Smart contracts
Lang. / Platforms	Smart contracts [Solidity]

Code Revision

N/A

Severity Categories

Severity	Description
Critical	The attack cost is low (not requiring much time or effort to succeed in the actual attack), and the vulnerability causes a high-impact issue. (e.g., Effect on service availability, Attacker taking financial gain)
High	An attacker can succeed in an attack which clearly causes problems in the service's operation. Even when the attack cost is high, the severity of the issue is considered "high" if the impact of the attack is remarkably high.
Medium	An attacker may perform an unintended action in the service, and the action may impact service operation. However, there are some restrictions for the actual attack to succeed.
Low	An attacker can perform an unintended action in the service, but the action does not cause significant impact or the success rate of the attack is remarkably low.
Informational	Any informational findings that do not directly impact the user or the protocol.
Note	Neutral information about the target that is not directly related to the project's safety and security.

Status Categories

Status	Description
Reported	ChainLight reported the issue to the client.
WIP	The client is working on the patch.
Patched	The client fully resolved the issue by patching the root cause.
Mitigated	The client resolved the issue by reducing the risk to an acceptable level by introducing mitigations.
Acknowledged	The client acknowledged the potential risk, but they will resolve it later.
Won't Fix	The client acknowledged the potential risk, but they decided to accept the risk.

Finding Breakdown by Severity

Category	Count	Findings
Critical	0	N/A
High	0	N/A
Medium	0	N/A
Low	0	N/A
Informational	1	GLUWASOULBOUND-001
Note	0	N/A

Findings

Summary

#	ID	Title	Severity	Status
1	GLUWASOULBOUND-001	Minor Suggestions	Informational	Patched

#1 GLUWASOULBOUND-001 Minor Suggestions

ID	Summary	Severity
GLUWASOULBOUND-001	The description includes multiple suggestions for preventing incorrect settings caused by operational mistakes, mitigating potential issues, and improving code maturity and readability.	Informational

Description

1. In the `getActiveArtifacts` function, it is recommended to return `activeArtifactIds` directly instead of constructing and returning a separate array.
2. In the `SoulboundNFT_init` function, it is recommended to rename the `name` and `symbol` arguments to `__name` and `__symbol` (or similar) to avoid variable shadowing.
3. Since `_mint` already performs the `_checkArtifactIsActive` check, it is recommended to remove the redundant `_checkArtifactIsActive` calls from the `mint`, `mintBatch`, and `mintBatchSpecificArtifact` functions.
4. Since the `fallback()` function is unnecessary, it is recommended to remove it.

Impact

Informational

Recommendation

Consider applying the suggestions in the description above.

Remediation

Patched

All issues have been patched as recommended.

Revision History

Version	Date	Description
1.0	March 10, 2026	Initial version

Theori, Inc. ("We") is acting solely for the client and is not responsible to any other party. Deliverables are valid for and should be used solely in connection with the purpose for which they were prepared as set out in our engagement agreement. You should not refer to or use our name or advice for any other purpose. The information (where appropriate) has not been verified. No representation or warranty is given as to accuracy, completeness or correctness of information in the Deliverables, any document, or any other information made available. Deliverables are for the internal use of the client and may not be used or relied upon by any person or entity other than the client. Deliverables are confidential and are not to be provided, without our authorization (preferably written), to entities or representatives of entities (including employees) that are not the client, including affiliates or representatives of affiliates of the client.

